

BEFORE Placeholder

AFTER

Integration Pattern: Logging & Audit Export (Supplier → Organisation)

Document classification: Internal

Pattern owner: Security Engineering/Architecture

Version: 0.1

Approved for use with tiers: Critical / Important (Low as applicable)

Last review: _____

1. Purpose

This pattern defines how supplier audit and security logs are enabled, retained, and exported to support detection, investigations, regulatory assurance, and operational resilience.

2. When to use

Use this pattern when a supplier:

- provides an admin console/tenant with audit logs, and/or
- supports SSO/RBAC (auth events, role changes), and/or
- integrates via API/agents/connectivity and generates security-relevant events, and/or
- is Tier Critical (mandatory) or Tier Important (where supported).

3. Default position

- Tier Critical suppliers MUST provide auditability for admin/auth events and a practical export/retrieval method.
- Prefer near-real-time forwarding for Critical suppliers when feasible; otherwise, use scheduled export.

- Logs must be tamper-resistant in practice (access controls, integrity, and restricted admin changes).

4. Log categories (minimum)

4.1 Required for Tier Critical (minimum)

MUST capture:

- Authentication events: login success/failure, MFA events (where available), SSO assertions (where available)
- Administrative actions: role changes, policy/config changes, security setting changes
- Integration events:
 - token/key issuance/rotation where available
 - API calls and especially write actions (where applicable)
- Data access/export events where the supplier supports it (especially for sensitive datasets)
- Sub-processor changes impacting service delivery (where supplier provides eventing)

4.2 Recommended for Tier Important

SHOULD capture:

- Admin actions and authentication events
- Integration/API activity where applicable
- Data export events (if available)

5. Export models (choose one)

Model A — Push / Forward (preferred for Critical)

Description:

- Supplier forwards logs to an organisation-controlled endpoint/collector.

Examples (generic):

- syslog/CEF to a collector
- cloud-to-cloud connector
- webhook/event streaming (where supported)

Minimum controls:

- TLS/mTLS where supported
- allowlist source IPs where possible
- dedicated integration identity with least privilege
- retry/queue behaviour defined (avoid silent drops)

Model B — Pull / API Retrieval

Description:

- Organisation pulls logs from supplier via API on a schedule.

Minimum controls:

- dedicated read-only API identity
- token stored in approved secrets store
- schedule and checkpointing (no gaps/duplicates)
- rate limiting handling
- documented backfill process

Model C — Manual Export (acceptable only where necessary)

Description:

- Portal export performed during reviews or investigations.

Minimum controls:

- named role allowed to export

- standard operating procedure (SOP) and frequency
- evidence retained
- escalate if Critical supplier only supports manual exports without compensating controls

6. Minimum requirements (baseline)

6.1 Enablement

MUST:

- Enable audit logging in the supplier tenant (where configurable).
- Restrict who can disable logging or change audit settings (admin RBAC).
- Document:
 - log types enabled
 - export model (A/B/C)
 - retention period
 - access roles for viewing/export

6.2 Retention

MUST:

- Define a retention period appropriate to tier and use case.
- Ensure logs remain accessible for investigations and audits during retention.

SHOULD (guidance; tailor to internal policy):

- Tier Critical: ≥ 12 months accessible (or per organisational standard)
- Tier Important: ≥ 6 months accessible (or per organisational standard)

6.3 Integrity and access control

MUST:

- Restrict access to logs to approved roles (least privilege).

- Ensure audit logs cannot be modified by normal users; admin access is limited and tracked.

SHOULD:

- Use immutable storage or write-once controls where the receiving platform supports it.
- Alert on attempts to disable logging or reduce retention.

6.4 Time synchronisation and timestamps

MUST:

- Ensure logs include timestamps with time zone (or UTC).
- Document expected time skew tolerance and any supplier limitations.

6.5 Monitoring and alerting (Critical recommended)

SHOULD:

- Alert on high-risk events such as:
 - new admin assignment
 - MFA disabled/auth policy change
 - logging disabled/retention reduced
 - unusual login patterns or geolocation (where available)
 - large data export events (where available)
 - API write spikes/out-of-hours writes

7. Implementation steps (high level)

1. Confirm required log categories for tier and integration type.
2. Select export model (A/B/C) and design the integration identity (least privilege).
3. Enable audit log categories in supplier tenant.
4. Configure forwarding/pull schedule and validate delivery.
5. Confirm retention settings and access controls.

6. Test with known events (admin role change, login, API call) and confirm logs are captured end-to-end.
7. Record evidence and sign off.

8. Validation checklist (sign-off)

Record evidence location for each item.

Enablement: ☐ Audit logs enabled (admin + auth minimum)

☐ Export model selected and documented (A/B/C)

☐ Roles able to disable/change logging restricted

Export: ☐ Forwarding/pull configured and tested

☐ Failure handling documented (retries/backfill)

☐ Source allowlists / secure transport configured (where applicable)

Retention & access: ☐ Retention period set and documented

☐ Access to logs restricted; admin access limited

☐ Log retrieval method tested (export sample)

Alerting (recommended): ☐ Alerts configured for high-risk events (where supported)

Sign-off: Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform

Owner (role title): _____ Date: _____ Business Service Owner (role title):

_____ Date: _____

9. Offboarding notes

On supplier offboarding:

- terminate forwarding/pull integrations and revoke credentials
- retain required logs per retention policy
- ensure exported logs remain accessible for the retention period